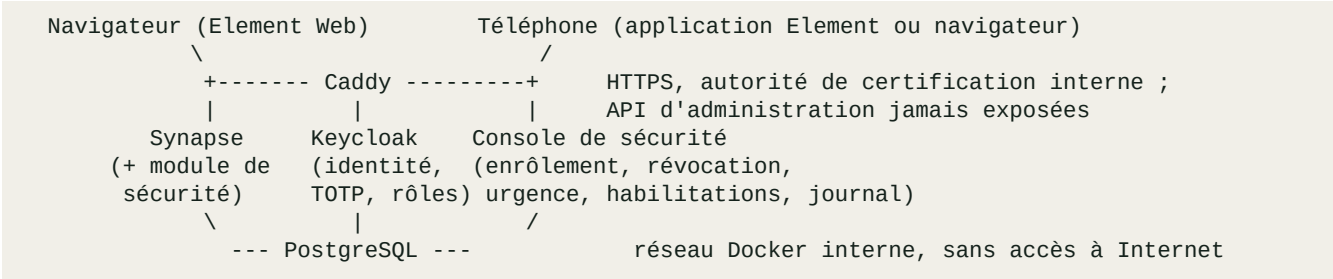
Note de pré-projet – Messagerie souveraine de l'administration

Équipe : Groupe Pegasus · **Défi** : la messagerie souveraine de l'administration · **Licence du code** : AGPL-3.0

1. Concept

Faute d'outil officiel, beaucoup d'agents échangent des informations de service sur des messageries grand public : données hébergées à l'étranger, groupes incontrôlés, et quand un agent quitte son poste ou perd son téléphone, **personne ne peut lui retirer l'accès**. Nous proposons une messagerie instantanée **web et mobile, hébergée par l'administration**, **chiffrée de bout en bout**, **réservée aux agents enrôlés** (mot de passe + second facteur), pilotée par une **console de sécurité** qui coupe l'accès d'un agent sur tous ses appareils en un clic. Elle s'installe en une commande et fonctionne même sur un réseau local **sans Internet**.

2. Architecture



Un agent se connecte toujours par **Keycloak** (mot de passe + code TOTP) ; Synapse n'accepte que les membres du groupe « agents ». La console pilote Keycloak et Synapse par leurs API d'administration ; notre **module serveur** applique les règles de sécurité dans Synapse.

3. Protocole de chiffrement retenu

Matrix Olm / Megolm, implémenté par **vodozemac** (Rust, audité publiquement) dans les applications Element : Olm (double ratchet, Curve25519, signatures Ed25519) échange les clés entre appareils ; Megolm chiffre les messages de groupe (**AES-256**, intégrité **HMAC-SHA-256**). Les clés restent sur les appareils. **L'équipe n'écrit aucune cryptographie** ; notre serveur **refuse** tout message non chiffré et tout retrait du chiffrement d'un salon.

4. Composants open source et licences

Composant	Rôle	Licence
Synapse 1.164.1	Serveur de messagerie Matrix	AGPL-3.0
Element Web 1.12.33, Element Android / iOS	Applications web et mobile	AGPL-3.0
vodozemac	Olm / Megolm	Apache-2.0
Keycloak 26.8.1	Identité, second facteur TOTP, rôles	Apache-2.0
PostgreSQL 16	Base de données	PostgreSQL License
Caddy 2.11.2	HTTPS et autorité de certification interne	Apache-2.0
Flask / Authlib / Requests / Gunicorn	Console de sécurité	BSD-3 / BSD-3 / Apache-2.0 / MIT
FreeOTP, Aegis (au choix)	Application TOTP hors ligne des agents	Apache-2.0 / GPL-3.0
pytest, pyotp, matrix-js-sdk	Tests automatisés	MIT / MIT / Apache-2.0
Docker Engine et Compose	Déploiement	Apache-2.0

5. Niveau d'engagement open source : « Étendre et adapter »

Nous ne modifions pas Synapse, Element ni Keycloak : nous les **configurons** pour la souveraineté (pas de fédération ni de service tiers), nous **étendons** Synapse par son API officielle de modules, et nous publions tout notre travail sous AGPL-3.0.

6. Fonctionnalités innovantes

- **Salons classifiés** `[DIFFUSION RESTREINTE]` / `[CONFIDENTIEL]` imposés par le serveur : accès réservé aux habilités, déclassement interdit, messages effacés après 30 / 7 jours.

- **Révocation coordonnée** identité + messagerie : compte désactivé, sessions fermées, tous les appareils déconnectés et retrait des conversations, en une à deux secondes.
- **Bouton d'urgence « téléphone perdu »** : appareils coupés, second facteur supprimé, réenrôlement avec un mot de passe provisoire remis en main propre.
- **Journal de sécurité** : intrus (compte inconnu ou non enrôlé), agents révoqués qui retentent, refus du serveur — jamais le contenu des messages.
- **41 tests de sécurité automatisés**, dont un échange chiffré réel dont le texte est recherché sans succès dans toute la base du serveur.

7. Répartition des rôles

Membre	Rôle dans le projet
[Nom 1]	Chef de projet, architecture et déploiement (Docker, installation)
[Nom 2]	Sécurité : chiffrement, identité (Keycloak, TOTP), note de sécurité
[Nom 3]	Développement : module serveur Synapse et console de sécurité
[Nom 4]	Tests automatisés, démonstration, vidéo et documentation

Suite envisagée : pilote dans un ministère ; application d'authentification libre redistribuée par l'administration, puis clés FIDO2 ; notifications hébergées par l'administration ; traductions en langues nationales proposées aux projets d'origine.